

DOSSIER AVOCAT · validation juridique

RGPD · ENTREPRISE

AIPD — Analyse d'Impact (DPIA) — Soundy [MODÈLE À COMPLÉTER]

Document interne — validation juridique requise avant diffusion ou signature · Généré le 03 août 2026

⚠ **Document indicatif.** Contenu produit par l'équipe produit à titre préparatoire ; il ne constitue pas un avis juridique. Seules les versions publiées in-app après validation avocat et complétion des données éditeur font foi.

Export pour revue avocat — version app : *juin 2026*

Source dépôt : `web/app/src/content/legal/dpia.ts`

1. Description du traitement concerné

Responsable du traitement : {{publisherName}} — {{address}} Contact DPO / référent RGPD : {{dpoEmail}}

Nom du traitement : Géolocalisation des utilisateurs et affichage sur carte

Finalité principale : Permettre aux utilisateurs de visualiser des salons d'écoute musicale et des lives à proximité, et d'être visibles des autres utilisateurs sur une carte géographique en temps réel.

Finalités secondaires : • Proposer du contenu géolocalisé (événements, lives, salons) à proximité • Calcul de distances entre utilisateurs (opt-in) • Mode « personnes proches » (opt-in)

Catégories de personnes concernées : Utilisateurs inscrits ayant activé la géolocalisation dans leur navigateur.

Catégories de données traitées : • Coordonnées GPS (latitude, longitude) — fournies par l'API de géolocalisation du navigateur • Position floutée (~50 m) — calculée côté serveur, affichée aux autres utilisateurs • Préférences de confidentialité (mode fantôme, précision ville, masquage distance) • Identifiant utilisateur (associé à la position) • Horodatage de la dernière mise à jour de position

Volumes estimés : [À REMPLIR — nombre d'utilisateurs actifs attendus]

2. Nécessité et proportionnalité

Base légale : Exécution du contrat (CGU) + consentement implicite par activation de la géolocalisation navigateur.

Justification de la nécessité : La géolocalisation est la fonctionnalité centrale du service : sans elle, l'affichage de la carte, la proximité des salons et la fonctionnalité « personnes proches » ne peuvent pas fonctionner. Elle

est strictement nécessaire à l'objet du service.

Minimisation des données : • La position brute n'est jamais divulguée aux autres utilisateurs — seule la position floutée (~50 m) l'est. • Mode fantôme : l'utilisateur peut se retirer complètement de la carte. • Option « ville uniquement » : seule la ville est partagée, sans coordonnées précises. • Option de ne pas partager la distance kilométrique. • La position n'est mise à jour qu'à la demande (action de l'utilisateur), pas en continu.

Durée de conservation : Dernière position mise à jour à chaque session active ; non conservée au-delà du nécessaire. Supprimée à la clôture du compte.

Destinataires : • Autres utilisateurs (position floutée uniquement) • Équipe technique pour maintenance et débogage (position brute — accès restreint) • [À REMPLIR : hébergeur / CDN — préciser si applicable]

3. Identification et évaluation des risques

Risque 1 — Réidentification malgré le floutage Vraisemblance : Moyenne (floutage ~50 m réducteur mais pas nul dans des zones peu denses) Gravité : Élevée (risque physique si localisation approchée exposée) Mesures d'atténuation :

- Floutage côté serveur avant tout affichage
- Option ville uniquement
- Mode fantôme disponible
- Rayon d'affichage limité (configurable) Risque résiduel : [À REMPLIR — acceptable / à réduire / inacceptable]

Risque 2 — Accès non autorisé à la base de données de positions Vraisemblance : Faible (accès restreint, authentification JWT) Gravité : Élevée (combinaison pseudonyme + position) Mesures d'atténuation :

- Authentification par jeton JWT sur toutes les routes API
- Contrôle d'accès par rôle
- Chiffrement HTTPS en production
- [À REMPLIR : chiffrement au repos des données ?] Risque résiduel : [À REMPLIR]

Risque 3 — Utilisation détournée par un autre utilisateur (stalking) Vraisemblance : Moyenne (risque inhérent aux applications sociales géolocalisées) Gravité : Élevée (risque physique pour les personnes vulnérables) Mesures d'atténuation :

- Floutage systématique
- Mode fantôme
- Fonction de blocage (masquage mutuel)
- Signalement et modération
- Limitation de fréquence de consultation de la carte
- [À REMPLIR : limitation du nombre de consultations de profil ?] Risque résiduel : [À REMPLIR]

Risque 4 — Fuite de données (data breach) Vraisemblance : Faible à moyenne Gravité : Élevée si données non chiffrées Mesures d'atténuation :

- Plan de notification CNIL (72 h, art. 33 RGPD)
- Sauvegardes chiffrées
- [À REMPLIR : procédure de réponse aux incidents documentée ?] Risque résiduel : [À REMPLIR]

4. Mesures envisagées pour traiter les risques

Mesures techniques : ☐ Chiffrement au repos des données de position dans la base de données ☐ Pseudonymisation des positions dans les logs (hash de l'identifiant) ☐ Purge automatique des positions après X jours d'inactivité ☐ [À REMPLIR : audit de sécurité du code de géolocalisation] ☐ Limitation de débit sur les endpoints de mise à jour de position ☐ Journalisation des accès aux données de position (audit trail)

Mesures organisationnelles : ☐ Formation de l'équipe aux bonnes pratiques RGPD ☐ Procédure documentée de réponse aux violations de données ☐ Revue périodique des accès aux données sensibles ☐ [À REMPLIR : registre des activités de traitement tenu à jour] ☐ Politique de mot de passe et 2FA pour l'accès admin

Information des utilisateurs : ☒ Politique de confidentialité détaillant le traitement de géolocalisation ☒ Interface permettant le contrôle fin (fantôme, ville, distance) ☐ [À REMPLIR : mention explicite lors de la première activation de la géolocalisation]

5. Sous-traitants impliqués

Cloudflare, Inc. Rôle : CDN, protection DDoS, proxy réseau Siège : San Francisco, CA, USA Transfert hors UE : Oui — Clauses Contractuelles Types (CCT) applicables DPA signé : [À REMPLIR — <https://www.cloudflare.com/cloudflare-customer-dpa/>] Données transitant : Adresses IP, requêtes HTTP (dont positions dans les URLs d'API) Minimisation : Cloudflare ne stocke pas les corps de requêtes API par défaut

Scaleway SAS (hébergeur) Rôle : Hébergement serveur, stockage base de données Siège : Paris, France — données hébergées en UE Transfert hors UE : Non DPA signé : [À REMPLIR — disponible dans l'espace client Scaleway] Données stockées : Toutes les données utilisateurs, dont positions

Stripe, Inc. Rôle : Traitement des paiements (pourboires, abonnements) Siège : Dublin, Irlande (entité UE pour les marchands européens) Transfert hors UE : Partiel — CCT applicables DPA signé : [À REMPLIR — <https://stripe.com/legal/dpa>] Données traitées : Données de paiement, identité partielle (e-mail, pays) Note : Stripe ne traite pas de données de géolocalisation Soundy

Resend (e-mail transactionnel) Rôle : Envoi d'e-mails (vérification, réinitialisation mot de passe, notifications) Siège : [À REMPLIR — vérifier localisation des serveurs] Transfert hors UE : [À REMPLIR] DPA signé : [À REMPLIR — <https://resend.com/legal/dpa>] Données traitées : Adresse e-mail, contenu de l'e-mail

OpenStreetMap / CARTO (tuiles cartographiques) Rôle : Affichage de la carte de fond Note : Les tuiles sont des images statiques. Votre compte Soundy n'est pas transmis à OSM/CARTO, mais les requêtes de tuiles partent du navigateur de l'utilisateur. DPA : Non requis (pas de données personnelles transmises au sens strict)

6. Avis de la personne concernée / consultation

Consultation des utilisateurs : [À REMPLIR] Les utilisateurs ont-ils été consultés sur ce traitement ? Méthode : • Enquête in-app ? ☐ • Test utilisateurs avec groupe représentatif ? ☐ • Analyse des retours support relatifs à la vie privée ? ☐

Avis du DPO (si désigné) : [À REMPLIR] Date de l'avis : Conclusions : Réserves éventuelles :

7. Conclusion et validation

Décision : [À REMPLIR — ☐ Traitement autorisé ☐ Traitement autorisé sous conditions ☐ Consultation CNIL requise]

Si consultation CNIL requise (art. 36 RGPD) : [À REMPLIR — référence dossier CNIL]

Signataire responsable du traitement : [À REMPLIR — nom, fonction, date] Signataire DPO (si désigné) : [À REMPLIR — nom, date]

Prochaine révision : [À REMPLIR — date de révision annuelle recommandée]

Note : Cette AIPD doit être révisée en cas de changement substantiel du traitement (nouveau sous-traitant, nouvelle finalité, augmentation significative du volume, changement technique affectant la sécurité).